

Cybersecurity Daily Newsletter

Vol. 003 | 2026-07-18 09:00 WIB

Top 5 Highlights

- New North Korean campaign uses fake coding interviews to steal developer credentials
- ACR Stealer exploits user interaction to steal sensitive data
- 2 charged in New York for laundering \$43 million from investment scams
- New Russian-speaking threat actor UAT-11795 targets US and Europe with novel malware
- Lawyers say Russian tourist detained in Armenia over mistaken identity in ransomware case

Threat Intelligence (10)

01. New North Korean campaign uses fake coding interviews to steal developer credentials

DPRK-aligned hackers hid malware inside SVG flag images to backdoor developer job interview coding tests. Not one antivirus vendor caught it.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.elastic.co/security-labs/contagious-interview-malware-svg-steganography>

02. New Russian-speaking threat actor UAT-11795 targets US and Europe with novel malware

UAT-11795 utilizes novel tools, including the Python-based Starland RAT and the PowerShell-based WLDR agent, which operates entirely in-memory with encrypted beaconing and a Runspace execution engine.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/new-russian-speaking-threat-actor-uat-11795-targets-us-and-europe-with-novel-malware>

03. MacOS malware hijacks Telegram sessions, targets crypto wallets

The macOS malware targets information stored locally on infected devices, including passwords, browser cookies, Apple Notes and Telegram Desktop session files.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.scworld.com/brief/macOS-malware-hijacks-telegram-sessions-targets-crypto-wallets>

04. Over 1 million malicious emails found using text salting to fool AI scanners

Text salting fills emails with hidden benign content to mask malicious phishing lures.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.scworld.com/news/over-1-million-malicious-emails-found-using-text-salting-to-fool-ai-scanners>

05. Seven Malicious Vite npm Packages Use Blockchain C2 to Deliver a RAT

Cybersecurity researchers have discovered a cluster of seven malicious npm packages targeting the Vite frontend tooling ecosystem as part of a software supply chain attack. The malicious package campaign, codenamed ViteVenom by Checkmarx, marks an expansion of ChainVeil, which was observed using an "unprecedented" four-tier blockchain-based command-and-control...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://thehackernews.com/2026/07/seven-malicious-vite-npm-packages-use.html>

06. New NadMesh Botnet Hunts Exposed AI Services for Cloud Keys and Kubernetes Tokens

A Go botnet called NadMesh turned up in early July hunting exposed AI services, and the operator's own dashboard claims 3,811 unique AWS keys. A Shodan harvester keeps the scan queue stocked with ComfyUI, Ollama, n8n, Open WebUI, Langflow, and Gradio: the image generators, local model runners, and workflow builders that teams stand up fast and firewall late...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/new-nadmesh-botnet-hunts-exposed-ai.html>

07. The Good, the Bad and the Ugly in Cybersecurity - Week 29

Authorities sanction Russian-based cybercriminals, attackers deploy Starland malware, and 300 imposter GitHub repos push BoryptGrab infostealer.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.sentinelone.com/blog/the-good-the-bad-and-the-ugly-in-cybersecurity-week-29-8/>

08. Microsoft at Black Hat USA 2026: Defending trust in the age of AI and supply chain attacks

Join Microsoft Security at Black Hat USA 2026 for supply chain research, hands-on security experiences, expert conversations, and our reception. The post Microsoft at Black Hat USA 2026: Defending trust in the age of AI and supply chain attacks appeared first on Microsoft Security Blog .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.microsoft.com/en-us/security/blog/2026/07/17/microsoft-at-black-hat-usa-2026-defending-trust-in-the-age-of-ai-and-supply-chain-attacks/>

09. Fake Coding Tests Deliver OtterCookie-Aligned Malware Hidden in SVG Flag Images

North Korean threat actors linked to the Contagious Interview campaign have been observed employing steganography in SVG image files to conceal malicious payloads as part of a campaign using fake job postings and coding challenges. "Any user who ran the project ended up with a four-stage payload aligned with OTTERCOOKIE: a browser credential and crypto wall...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/north-korea-linked-hackers-hide.html>

10. How to use GitHub safely

Knowing how to spot a malicious GitHub repository can help you avoid downloading malware disguised as legitimate software.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.malwarebytes.com/blog/how-to/2026/07/how-to-use-github-safely>

Latest Vulnerabilities (10)

01. ACR Stealer exploits user interaction to steal sensitive data

Microsoft has detailed two primary intrusion chains used by ACR Stealer.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/acr-stealer-exploits-user-interaction-to-steal-sensitive-data>

02. SoftBank leverages OpenAI for AI-driven cybersecurity patching service

SoftBank's "Patching as a Service" (PaaS), powered by a joint venture with OpenAI called SB OAI Japan, offers clients AI-infused remediation planning and vulnerability assessment.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/brief/softbank-leverages-openai-for-ai-driven-cybersecurity-patching-service>

03. New wp2shell WordPress Core Flaw Lets Unauthenticated Attackers Run Code

An anonymous HTTP request can run code on a WordPress site. The bug is in core, so a bare install with zero plugins is exploitable. Every 6.9 and 7.0 site was in range until Friday, when WordPress shipped 6.9.5 and 7.0.2 and enabled what it calls forced updates through its auto-update system. Adam Kues at Assetnote, Searchlight Cyber's attack surface manage...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/new-wp2shell-wordpress-core-flaw-lets.html>

04. OpenSSL HollowByte Flaw Could Freeze Server Memory with 11-Byte TLS Requests

Eleven bytes will make an unpatched OpenSSL server set aside up to 131 KB of memory for a message that never arrives. On the glibc systems Okta tested, that memory is gone until the process restarts. OpenSSL shipped the HollowByte fix in June with no CVE, no advisory, and no changelog entry pointing at it. Okta's Red Team, which reported the denial-of-servi...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/openssl-hollowbyte-flaw-could-freeze.html>

05. Inc Ransomware Exploits SonicWall SMA Zero-Days

When chained together, the two vulnerabilities allow threat actors to gain root-level capabilities on SonicWall's mobile access appliances.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.darkreading.com/vulnerabilities-threats/inc-ransomware-exploits-sonicwall-sma-zero-days>

06. HollowByte DDoS flaw bloats OpenSSL server memory with 11-byte payload

A vulnerability dubbed HollowByte allows unauthenticated attackers to trigger a denial-of-service (DoS) condition on OpenSSL servers with a malicious payload of just 11 bytes. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/hollowbyte-ddos-flaw-bloats-openssl-server-memory-with-11-byte-payload/>

07. Gold Eagle Clearinghouse Targets Security Gap, but How Is Unclear

The White House launched Gold Eagle to coordinate vulnerability response in a new AI world, but multiple questions linger over how it's being implemented.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.darkreading.com/vulnerabilities-threats/gold-eagle-clearinghouse-targets-security-gap>

08. New CISO appointments 2026

The upper ranks of corporate security are seeing a high rate of change as companies try to adapt to the evolving threat landscape. Many companies are hiring a chief security officer (CSO) or chief information security officer (CISO) for the first time to support a deeper commitment to information security. Follow this column to keep up with new appointments...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4186743/new-ciso-appointments-2026.html>

09. Attackers target critical FortiSandbox flaws as CISA issues patch order

Command injection vulns land on exploited list after researchers spot abuse attempts

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.theregister.com/security/2026/07/17/attackers-target-critical-fortisandbox-flaws-as-cisa-issues-patch-order/5274287>

10. The Race to Field Military Autonomy Is On, Can Trusted Information Infrastructure Keep Pace?

Military forces are under increasing pressure to field autonomous capabilities faster than ever before. Across the U.S., UK, and NATO, new investment, evolving defense strategies, and accelerated acquisition pathways are transforming how capability is delivered, rewarding programs that can move from concept to operational deployment at commercial speed. Now...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/the-race-to-field-military-autonomy-is.html>

Data Breach & Cybercrime (10)

01. 2 charged in New York for laundering \$43 million from investment scams

Zhuoying Chen, 27, and Haojie Zhang, 38, are accused of managing a network that transferred at least \$43 million to China, based on information published by Bleeping Computer.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/two-charged-in-new-york-for-laundering-43-million-from-investment-scams>

02. Lawyers say Russian tourist detained in Armenia over mistaken identity in ransomware case

The detained Russian, Aleksandr Yuryevich Ermakov, was apprehended in Armenia on June 28, based on a U.S. request.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.scworld.com/brief/russian-tourist-detained-in-armenia-over-mistaken-identity-in-us-extradition-request>

03. Abbott probes two cyber incidents amid extortion claims

Abbott Laboratories is investigating two separate cybersecurity incidents after confirming unauthorized access to internal legacy Exact Sciences systems in its Cancer Diagnostics business, while also investigating a separate claim that attackers breached its LabCentral portal and stole company data. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/abbott-laboratories-probes-two-cyber-incidents-amid-extortion-claims/>

04. OnlyFans performers become unlikely allies of CISOs in securing websites

CISOs at government organizations and universities have an unexpected ally coming to their aid: OnlyFans models. For some time, hackers have exploited weaknesses in the websites of universities or government departments to host scams or malware, using content stolen from the OnlyFans website as bait to attract victims. Now, according to security researchers...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.csoonline.com/article/4198478/onlyfans-performers-become-unlikely-allies-of-cisos-in-securing-websites.html>

05. GoldenEyeDog Subgroup Linked to DigiCert Breach and Code-Signing Certificate Theft

Cybersecurity researchers have attributed the April 2026 DigiCert security incident to a threat activity cluster dubbed CylindricalCanine. Expel, which shared technical details of the event, described the threat actor as a sub-group of GoldenEyeDog (aka APT-Q-27, Dragon Breath, and Miutu Group), a Chinese cybercrime group known for its targeting of the gam...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/07/goldeneyedog-subgroup-linked-to.html>

06. Government Agencies Falling Victim to Ransomware Daily, Warns Study

Government organizations are targeted by attackers who know agencies cannot afford disruption to public services

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/government-ransomware-daily/>

07. Ernst & Young discloses data breach after support system hack

Ernst & Young is notifying customers of a data breach caused by the compromise of a third-party support ticket system used by its IT personnel. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/ernst-and-young-discloses-data-breach-after-support-system-hack/>

08. 23andMe Faces New Security Mandates in \$18m Data Breach Settlement

23andMe has agreed to an \$18m settlement with 42 US attorneys general over its 2023 data breach, including enhanced data protection requirements

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/23andme-18m-data-breach-settlement/>

09. In Other News: Iran Tracks US Military Phones, CrashStealer macOS Malware, CVD Blueprint

Noteworthy stories that might have slipped under the radar: OpenClaw AI agents exploited via WhatsApp, ransomware hits naval defense firm TKMS, Lidl discloses data breach. The post In Other News: Iran Tracks US Military Phones, CrashStealer macOS Malware, CVD Blueprint appeared first on SecurityWeek .

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.securityweek.com/in-other-news-iran-tracks-us-military-phones-crashstealer-macos-malware-cvd-blueprint/>

10. Inside the Search for "Clean" Residential Proxies for Carding

Residential proxies are no longer the silver bullet they once were for carding. Flare explains why cybercriminals increasingly seek "clean" residential proxies and combine them with browser fingerprints, device profiles, and other identity signals to evade modern fraud detection. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/inside-the-search-for-clean-residential-proxies-for-carding/>